

MARCO INTEGRATIVO QQM + PRAGMATIC

Trazabilidad desde Objetivos Nacionales hasta Datos Técnicos

CIA Triad Metrics Framework — España 2025

*"Medir sin objetivo es coleccionar números. Medir sin criterio de calidad es coleccionar ilusiones.
La combinación QQM + PRAGMATIC convierte ambas colecciones en conocimiento accionable."*

PARTE I: FUNDAMENTOS TEÓRICOS DEL MARCO INTEGRATIVO

1.1 La Metodología QQM (Goal-Question-Metric)

La metodología QQM fue desarrollada originalmente por Victor Basili y David Weiss en el NASA Software Engineering Laboratory (1984) y formalizada por Basili, Caldiera y Rombach (1994). Su estructura tripartita establece que toda métrica debe derivarse de una pregunta, y toda pregunta de un objetivo explícito y declarado.

Estructura jerárquica QQM:

NIVEL 1 — CONCEPTUAL:	OBJETIVO (Goal)
	↓
NIVEL 2 — OPERACIONAL:	PREGUNTA (Question)
	↓
NIVEL 3 — CUANTITATIVO:	MÉTRICA (Metric)

Cada objetivo se define mediante cuatro dimensiones:

- **Propósito:** ¿Qué se quiere hacer? (mejorar, evaluar, monitorizar, predecir)
- **Objeto:** ¿Sobre qué entidad? (proceso, producto, recurso, modelo)
- **Atributo:** ¿Qué característica? (calidad, coste, eficiencia, fiabilidad)
- **Punto de vista:** ¿Desde qué perspectiva? (CISO, Consejo, regulador, ciudadano)

1.2 El Marco PRAGMATIC

El marco PRAGMATIC, desarrollado por Brothby y Hinson (2013) en su obra *"A Practical Introduction to Information Security Measurement"* y adoptado posteriormente por el ISACA y el NIST en sus guías de métricas de seguridad, establece nueve criterios de calidad que toda métrica debe satisfacer para ser operacionalmente válida.

Los nueve criterios PRAGMATIC:

Criterio	Letra	Definición operacional	Pregunta de evaluación
Predictivo	P	La métrica anticipa resultados futuros o tendencias de riesgo	¿Permite prever incidentes o degradación antes de que ocurran?
Relevante	R	La métrica mide algo que realmente importa para los objetivos de negocio	¿Es pertinente para las decisiones que deben tomarse?
Accionable	A	El resultado de la métrica deriva en decisiones concretas	¿Qué acción específica genera cada valor de la métrica?
Genuino	G	La métrica mide lo que dice medir, sin sesgos ni sustitutos	¿Mide el fenómeno real o un proxy inadecuado?
Measurable (Significativo)	M	La métrica puede obtenerse con esfuerzo razonable	¿Puede calcularse de forma práctica y reproducible?
Accurate (Preciso)	A2	La métrica tiene suficiente exactitud para ser útil	¿El margen de error es aceptable para la decisión que soporta?
Timely (Oportuno)	T	La métrica está disponible cuando se necesita	¿Puede obtenerse con la frecuencia requerida?
Independent (Independiente)	I	La métrica no puede ser manipulada por quien es medido	¿Puede verificarse externamente?
Cost-effective (Rentable)	C	El coste de obtención es proporcional al valor generado	¿El beneficio informacional supera el coste de medición?

Escala de evaluación PRAGMATIC (por criterio):

- **3** — Cumple plenamente el criterio
- **2** — Cumple parcialmente
- **1** — Cumple de forma marginal
- **0** — No cumple

Puntuación total máxima: 27 puntos (9 criterios × 3)

Interpretación:

- 24-27: Métrica de calidad óptima (Clase A)
- 18-23: Métrica de buena calidad (Clase B)
- 12-17: Métrica aceptable con reservas (Clase C)
- < 12: Métrica a revisar o reemplazar (Clase D)

1.3 La Sinergia QQM + PRAGMATIC

La integración de ambos marcos crea un sistema de doble validación:

1. QQM asegura la trazabilidad vertical: que cada dato técnico responde a una pregunta que responde a un objetivo estratégico.
2. PRAGMATIC asegura la calidad horizontal: que cada métrica cumple los estándares de utilidad para la toma de decisiones.

OBJETIVO NACIONAL (ENS/NIS2/DORA)
↓ [QQM: trazabilidad]
OBJETIVO ORGANIZACIONAL (CISO)
↓
PREGUNTAS DE MEDICIÓN (¿cómo sabemos si lo logramos?)
↓
MÉTRICAS TÉCNICAS (indicadores cuantificables)
↓ [PRAGMATIC: calidad]
DECISIONES EJECUTIVAS (acción sobre riesgo)

PARTE II: OBJETIVOS NACIONALES — EL NIVEL ESTRATÉGICO

2.1 Objetivos Derivados del Marco Regulatorio Español y Europeo

OBJ-NAC-01 (ENS / NIS2):

Garantizar que las organizaciones españolas clasificadas como operadores esenciales o entidades importantes implementen controles de confidencialidad que protejan la información de usuarios, ciudadanos e infraestructuras críticas.

Propósito: Evaluar | **Objeto:** Controles de confidencialidad | **Atributo:** Cobertura y efectividad | **Perspectiva:** Regulador (CCN/INCIBE)

OBJ-NAC-02 (ENS / ISO 27001 / NIST CSF 2.0):

Asegurar que la integridad de los sistemas de información críticos se mantenga mediante controles preventivos, detectivos y correctivos documentados y verificados.

Propósito: Evaluar | **Objeto:** Controles de integridad | **Atributo:** Robustez y verificabilidad | **Perspectiva:** CISO / Auditor

OBJ-NAC-03 (DORA / NIS2 / ISO 22301):

Garantizar la disponibilidad continuada de servicios digitales críticos con objetivos de recuperación (RTO/RPO) definidos, probados y alineados con los requisitos de resiliencia operativa digital.

Propósito: Mejorar | **Objeto:** Resiliencia operativa | **Atributo:** Disponibilidad y tiempos de recuperación | **Perspectiva:** Consejo de Administración / Regulador financiero

OBJ-NAC-04 (eIDAS 2 / ENS / DORA):

Asegurar la autenticidad e irrefutabilidad de las transacciones digitales y comunicaciones críticas mediante mecanismos de firma digital cualificada y trazabilidad de sesiones privilegiadas.

Propósito: Mejorar | **Objeto:** Mecanismos de autenticidad | **Atributo:** Cobertura y no repudio |
Perspectiva: DPO / Compliance

OBJ-NAC-05 (RGPD / ENS / EU AI Act):

Controlar los riesgos emergentes derivados del uso no supervisado de inteligencia artificial y el shadow IT, garantizando la gobernanza de datos y la privacidad por diseño.

Propósito: Controlar | **Objeto:** Gobernanza de IA y shadow IT | **Atributo:** Inventario y política |
Perspectiva: DPO / CISO

OBJ-NAC-06 (NIST PQC / NSA CNSA 2.0 / CCN):

Iniciar la transición a algoritmos criptográficos post-cuánticos para proteger la confidencialidad e integridad de la información a largo plazo frente a la amenaza de "Harvest Now, Decrypt Later".

Propósito: Predecir y preparar | **Objeto:** Criptografía en uso | **Atributo:** Cripto-agilidad y quantum-readiness | **Perspectiva:** CISO / Estratega

PARTE III: ÁRBOL GQM COMPLETO — LOS 22 INDICADORES CIA TRIAD

PILAR CONFIDENCIALIDAD (C)

INDICADOR C-01: Tasa de Cobertura MFA (MFA Coverage Rate)

OBJETIVO (G):

Mejorar la protección de las credenciales de acceso en todos los sistemas de información de la organización para reducir el riesgo de compromiso de identidad como vector de brecha, en el marco del Art. 21(2)(i) NIS2 y ENS Op.acc.5.

PREGUNTAS (Q):

- Q1.1: ¿Qué porcentaje de usuarios activos tienen MFA habilitado sobre el total de cuentas con acceso a sistemas de información?
- Q1.2: ¿Qué proporción de las cuentas con MFA utiliza métodos resistentes al phishing (FIDO2/WebAuthn) vs. métodos susceptibles (SMS/TOTP)?
- Q1.3: ¿Cuál es la tasa de intentos de bypass de MFA detectados en los últimos 90 días?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-C01a	MFA Coverage Rate	(Cuentas con MFA activo / Total cuentas activas) $\times$ 100	%	Mensual	< 70% – Alerta	$\geq$ 99%
M-C01b	Phishing-Resistant MFA Rate	(Cuentas FIDO2 / Total cuentas con MFA) $\times$ 100	%	Trimestral	< 30%	$\geq$ 80%
M-C01c	MFA Bypass Attempt Rate	(Intentos bypass / Total intentos autenticación) $\times$ 100	%	Semanal	> 0,5%	< 0,01%

Fuentes de datos: Directorio activo (AD/LDAP), IAM platform, SIEM logs de autenticación

Referencia normativa: NIST SP 800-63B AAL2/AAL3; ENS Op.acc.5; NIS2 Art. 21(2)(i); FIDO Alliance

INDICADOR C-02: Índice de Madurez IAM (IAM Maturity Index)

OBJETIVO (G):

Evaluar el grado de implementación del ciclo de vida de identidades y accesos (IAM) para asegurar que el principio de mínimo privilegio se aplica de forma sistemática y verificable, cumpliendo ISO 27001 A.5.15-5.18 y ENS Op.acc.4-6.

PREGUNTAS (Q):

- Q2.1: ¿Existe un proceso documentado y automatizado de alta, modificación y baja de cuentas de usuario?
- Q2.2: ¿Con qué frecuencia se revisan los privilegios de acceso a sistemas críticos?
- Q2.3: ¿Qué porcentaje de cuentas de administrador están cubiertas por una solución PAM con grabación de sesiones?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-C02a	Orphan Account Rate	$(\text{Cuentas huérfanas activas} / \text{Total cuentas}) \times 100$	%	Mensual	> 5%	< 0,5%
M-C02b	Access Review Frequency Score	$\text{Revisiones formales completadas} / \text{Revisiones programadas (trimestral = 4/año)}$	Ratio 0-1	Trimestral	< 0,5	= 1,0
M-C02c	PAM Coverage Rate	$(\text{Cuentas admin cubiertas por PAM} / \text{Total cuentas admin}) \times 100$	%	Mensual	< 80%	= 100%
M-C02d	Least Privilege Score	$(\text{Usuarios con mínimos privilegios verificados} / \text{Total usuarios}) \times 100$	%	Trimestral	< 60%	≥ 95%

Fuentes de datos: IAM platform, HR system (bajas), AD audit logs, PAM tool

Referencia normativa: ISO 27001:2022 A.5.15-5.18; ENS Op.acc.4-6; NIST SP 800-53 AC-2, AC-6

INDICADOR C-03: Tasa de Cobertura de Cifrado en Reposo (Encryption at Rest Coverage)

OBJETIVO (G):

Garantizar que todos los datos clasificados como confidenciales o de carácter personal están cifrados en reposo con algoritmos aprobados, en cumplimiento del RGPD Art. 32(1)(a), ENS Mp.si.2 e ISO 27001 A.8.24.

PREGUNTAS (Q):

- Q3.1: ¿Qué porcentaje de repositorios de datos sensibles (BD, ficheros, backups) están cifrados en

reposito?

- Q3.2: ¿Se utilizan algoritmos de cifrado actuales y no deprecados (AES-256, ChaCha20)?
- Q3.3: ¿El sistema de gestión de claves (KMS) está separado del sistema que cifra los datos?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-C03a	Encryption at Rest Coverage	(Repositorios cifrados / Total repositorios datos sensibles) × 100	%	Mensual	< 80%	= 100%
M-C03b	Cryptographic Algorithm Compliance	(Repos con algoritmos aprobados / Total repos cifrados) × 100	%	Trimestral	< 100% → Alerta	= 100%
M-C03c	KMS Separation Score	Binario: KMS separado y con acceso controlado = 1; otro = 0	0/1	Semestral	= 0 → Crítico	= 1

Fuentes de datos: Inventario de activos, escáneres de configuración (CSPM), auditoría KMS

Referencia normativa: RGPD Art. 32(1)(a); ISO 27001 A.8.24; ENS Mp.si.2; CCN-STIC-807

INDICADOR C-04: Índice de Cripto-Agilidad PQC (Post-Quantum Crypto Agility Index)

OBJETIVO (G):

Predecir y gestionar proactivamente el riesgo de obsolescencia criptográfica ante la amenaza cuántica, iniciando el inventario de algoritmos en uso y la hoja de ruta de migración a los estándares NIST PQC (FIPS 203/204/205), alineado con NSA CNSA 2.0.

PREGUNTAS (Q):

- Q4.1: ¿Existe un inventario completo de los algoritmos criptográficos en uso en todos los sistemas?
- Q4.2: ¿Qué porcentaje de sistemas críticos utilizan algoritmos vulnerables a ataques cuánticos (RSA, ECC, DH) sin plan de migración?
- Q4.3: ¿Se ha completado algún piloto de implementación PQC (ML-KEM, ML-DSA)?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-C04a	Crypto Inventory Completeness	$(\text{Sistemas con algoritmos inventariados} / \text{Total sistemas}) \times 100$	%	Semestral	< 50%	= 100%
M-C04b	Quantum-Vulnerable Exposure Rate	$(\text{Sistemas críticos con algoritmos Q-vulnerables sin plan migración} / \text{Total sistemas críticos}) \times 100$	%	Semestral	> 80%	< 10% (2030)
M-C04c	PQC Migration Progress Score	Etapas alcanzadas en roadmap (0=sin iniciar; 1=inventario; 2=piloto; 3=producción parcial; 4=producción total)	Escala 0-4	Semestral	= 0	≥ 2 (2026)

Fuentes de datos: Escáneres de criptografía (Cryptosense, IBM Guardium), inventario de certificados

Referencia normativa: NIST FIPS 203 (ML-KEM), FIPS 204 (ML-DSA), FIPS 205 (SLH-DSA); NSA CNSA 2.0; CCN en desarrollo

INDICADOR C-05: Tasa de Cobertura DLP (Data Loss Prevention Coverage Rate)

OBJETIVO (G):

Controlar y prevenir la exfiltración de datos sensibles a través de canales digitales no autorizados, midiendo la efectividad de los controles DLP implementados en cumplimiento de RGPD Art. 25 (privacidad por diseño) e ISO 27001 A.5.12-5.13.

PREGUNTAS (Q):

- Q5.1: ¿Qué porcentaje del tráfico de salida de la organización está analizado por controles DLP?

- Q5.2: ¿Cuántos incidentes de exfiltración potencial fueron detectados y bloqueados en los últimos 90 días?
- Q5.3: ¿Cuál es la tasa de falsos positivos del sistema DLP?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-C05a	DLP Coverage Rate	$(\text{Canales monitorizados por DLP} / \text{Total canales de salida}) \times 100$	%	Mensual	< 70%	≥ 95%
M-C05b	DLP Block Rate	$(\text{Eventos bloqueados} / \text{Total eventos DLP disparados}) \times 100$	%	Semanal	— (referencia)	Según política
M-C05c	DLP False Positive Rate	$(\text{Alertas DLP sin incidente real} / \text{Total alertas DLP}) \times 100$	%	Mensual	> 30%	< 10%

Fuentes de datos: Plataforma DLP (Symantec, Microsoft Purview, Forcepoint), SIEM

Referencia normativa: RGPD Art. 25; ISO 27001 A.5.12-5.13; ENS Mp.info.3; NIST SP 800-53 SI-12

INDICADOR C-06: Índice de Gobernanza Shadow AI (Shadow AI Governance Index)

OBJETIVO (G):

Controlar los riesgos de confidencialidad e integridad derivados del uso no autorizado de herramientas de inteligencia artificial generativa en procesos organizacionales, midiendo la cobertura del inventario y la madurez de la política de gobernanza de IA, en cumplimiento del EU AI Act Art. 28 y RGPD Art. 5.

PREGUNTAS (Q):

- Q6.1: ¿Qué porcentaje de herramientas de IA en uso en la organización están inventariadas y evaluadas?
- Q6.2: ¿Existe una política formal de uso de IA generativa con categorías de datos prohibidas?
- Q6.3: ¿Se realizan auditorías de uso de IA no autorizada?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-C06a	Shadow AI Inventory Rate	(Herramientas IA inventariadas y evaluadas / Total herramientas IA detectadas) × 100	%	Trimestral	< 50%	≥ 95%
M-C06b	AI Governance Policy Maturity	Escala CMMI 0-5: 0=sin política; 1=informal; 2=documentada; 3=aprobada; 4=controlada; 5=optimizada	Escala 0-5	Semestral	< 2	≥ 4
M-C06c	Unauthorized AI Use Detection Rate	Instancias Shadow AI detectadas en auditoría / Período	Número	Trimestral	— (referencia)	Tendencia decreciente

Fuentes de datos: CASB (Cloud Access Security Broker), proxy logs, auditorías de usuarios

Referencia normativa: EU AI Act Art. 9, 28; RGPD Art. 5, 25; ISO/IEC 42001:2023; ENS (en actualización)

PILAR INTEGRIDAD (I)

INDICADOR I-01: Tasa de Cobertura FIM (File Integrity Monitoring Coverage)

OBJETIVO (G):

Detectar modificaciones no autorizadas en ficheros y configuraciones de sistemas críticos de forma automatizada y en tiempo real, garantizando la integridad operacional en cumplimiento de NIST SP 800-53 SI-7, PCI-DSS Req. 11.5 y ENS Mp.sw.2.

PREGUNTAS (Q):

- Q7.1: ¿Qué porcentaje de sistemas críticos tienen implementado monitorización de integridad de

ficheros (FIM)?

- Q7.2: ¿Cuál es el tiempo medio de detección de una modificación no autorizada?
- Q7.3: ¿Los alertas FIM están integrados en el SIEM y tienen proceso de respuesta definido?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-I01a	FIM Coverage Rate	(Sistemas críticos con FIM activo / Total sistemas críticos) × 100	%	Mensual	< 80%	= 100%
M-I01b	FIM Detection Time	Tiempo medio entre modificación no autorizada y alerta generada	Minutos	Por evento	> 60 min	< 5 min
M-I01c	FIM Alert-to-SIEM Integration	Binario: FIM integrado en SIEM con playbook de respuesta = 1; otro = 0	0/1	Trimestral	= 0	= 1

Fuentes de datos: FIM tool (Tripwire, AIDE, Wazuh), SIEM, inventario de sistemas críticos

Referencia normativa: NIST SP 800-53 SI-7; PCI-DSS v4.0 Req. 11.5; ENS Anexo II Mp.sw.2; ISO 27001 A.8.8

INDICADOR I-02: Tiempo Mediano de Parcheo de Vulnerabilidades Críticas (TMPVC)

OBJETIVO (G):

Reducir la ventana de exposición de vulnerabilidades críticas (CVSS ≥ 9.0) y altas (CVSS ≥ 7.0) en sistemas de producción al mínimo posible, cumpliendo los SLA normativos de NIS2 Art. 21(2)(b), ENS Op.exp.4 y DORA Art. 9(3).

PREGUNTAS (Q):

- Q8.1: ¿Cuántos días transcurren entre la publicación de una vulnerabilidad crítica (CVSS ≥ 9.0) y su

parqueo en producción?

- Q8.2: ¿Cuál es el número de vulnerabilidades críticas sin parche con más de 30 días de antigüedad?
- Q8.3: ¿Se aplica priorización basada en explotabilidad activa (EPSS, CISA KEV) para acelerar el parcheo?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-I02a	TMPVC (Críticas)	Mediana de días entre publicación CVE crítico y parcheo en prod	Días	Semanal	> 30 días	≤ 15 días
M-I02b	TMPVA (Altas)	Mediana de días entre publicación CVE alto y parcheo en prod	Días	Mensual	> 90 días	≤ 30 días
M-I02c	Unpatched Critical Vulnerabilit y Age	Número de CVE críticos sin parche con edad > 30 días	Número	Semanal	> 0 → Alerta	= 0
M-I02d	EPSS-Prioritized Patch Rate	(CVE con EPSS > 0,5 parcheados en ≤ 7 días / Total CVE EPSS > 0,5) × 100	%	Semanal	< 80%	= 100%

Fuentes de datos: Vulnerability scanner (Tenable, Qualys, Rapid7), CISA KEV feed, NVD/CVE database

Referencia normativa: NIS2 Art. 21(2)(b); ENS Op.exp.4; DORA Art. 9(3); NIST SP 800-53 RA-5; CVSS v3.1/v4.0

INDICADOR I-03: Índice de Integridad de la Cadena de Suministro (Supply Chain Integrity Index)

OBJETIVO (G):

Evaluar y controlar los riesgos de integridad derivados de componentes software de terceros, asegurando la verificabilidad criptográfica de las entregas de software y la disponibilidad de inventario SBOM, en alineación con EU Cyber Resilience Act, NIS2 Art. 21(2)(d) y NIST SP 800-218.

PREGUNTAS (Q):

- Q9.1: ¿Qué porcentaje del software en producción tiene SBOM disponible y actualizado?
- Q9.2: ¿Se verifica criptográficamente la integridad (hash/firma) de los artefactos de software antes de despliegue?
- Q9.3: ¿Cuántos incidentes de seguridad en el último año tuvieron como vector a un tercero proveedor?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-I03a	SBOM Coverage Rate	$(\text{Aplicaciones con SBOM actualizado} / \text{Total aplicaciones en prod}) \times 100$	%	Trimestral	< 20%	$\geq 80\%$ (2026)
M-I03b	Software Artifact Verification Rate	$(\text{Artefactos verificados criptográficamente en pipeline CI/CD} / \text{Total artefactos desplegados}) \times 100$	%	Mensual	< 80%	= 100%
M-I03c	Third-Party Breach Rate	Incidentes originados en terceros / Total incidentes de seguridad	Ratio	Anual	> 30%	< 10%

Fuentes de datos: SBOM tooling (Syft, SPDX, CycloneDX), CI/CD pipeline logs, ITSM (registro de incidentes)

Referencia normativa: EU Cyber Resilience Act Art. 13(5); NIS2 Art. 21(2)(d); NIST SP 800-218 (SSDF); DORA Art. 28

INDICADOR I-04: Tasa de Firma Digital (Digital Signature Coverage Rate)

OBJETIVO (G):

Garantizar la autenticidad e irrefutabilidad de los documentos, transacciones y comunicaciones críticas mediante firma digital cualificada conforme a eIDAS 2, DORA Art. 9 y ENS (dimensión Autenticidad).

PREGUNTAS (Q):

- Q10.1: ¿Qué porcentaje de transacciones críticas (contratos, comunicaciones reguladas) están firmadas digitalmente con certificado cualificado?
- Q10.2: ¿La infraestructura PKI está actualizada y las CRL/OCSP son accesibles?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-I04a	Digital Signature Coverage	$(\text{Transacciones críticas firmadas} / \text{Total transacciones críticas}) \times 100$	%	Mensual	< 80%	= 100%
M-I04b	PKI Health Score	$(\text{Certificados válidos y no expirados} / \text{Total certificados en uso}) \times 100$	%	Semanal	< 100% → Alerta	= 100%
M-I04c	Certificate Expiry Advance Notice	Días medios de antelación en renovación de certificados antes de expiración	Días	Mensual	< 30 días	≥ 90 días

Fuentes de datos: PKI management tool, Certificate Transparency logs, OCSP/CRL monitoring

Referencia normativa: eIDAS 2 (UE 2024/1183); DORA Art. 9; ENS Dimensión Autenticidad; ISO 27001 A.8.24

INDICADOR I-05: Índice de Integridad de Logs (Log Integrity and Immutability Index)

OBJETIVO (G):

Asegurar que los registros de auditoría de sistemas críticos son completos, íntegros, inmutables y conservados durante el período reglamentario, garantizando la capacidad de respuesta forense y el cumplimiento de NIS2 Art. 21(2)(f), ENS Op.exp.10 y DORA Art. 13(7).

PREGUNTAS (Q):

- Q11.1: ¿Qué porcentaje de sistemas críticos envían logs a un SIEM centralizado con almacenamiento inmutable?
- Q11.2: ¿Cuál es el período de retención de logs para sistemas de alta criticidad?
- Q11.3: ¿Se realizan verificaciones periódicas de integridad de los logs almacenados?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-I05a	Log Centralization Rate	(Sistemas críticos con logs en SIEM centralizado / Total sistemas críticos) × 100	%	Mensual	< 80%	= 100%
M-I05b	Log Retention Compliance	(Sistemas con retención ≥ 12 meses / Total sistemas regulados) × 100	%	Trimestral	< 100% → Alerta	= 100% (≥ 24m ENS Alto)
M-I05c	Log Integrity Verification Rate	(Verificaciones de integridad completadas / Verificaciones programadas)	Ratio	Mensual	< 1,0	= 1,0

Fuentes de datos: SIEM (Splunk, QRadar, Microsoft Sentinel), log management platform

Referencia normativa: NIS2 Art. 21(2)(f); ENS Op.exp.10 (2 años nivel Alto); DORA Art. 13(7); NIST SP 800-53 AU-9

PILAR DISPONIBILIDAD (A)

INDICADOR A-01: Tiempo Medio de Detección (MTTD — Mean Time to Detect)

OBJETIVO (G):

Reducir el tiempo transcurrido entre la ocurrencia de un incidente de seguridad y su detección por los sistemas o el equipo de seguridad, minimizando la ventana de exposición y los costes asociados al incidente no detectado, en alineación con NIST CSF 2.0 DE.CM y los datos de referencia IBM Cost of Data Breach 2025 (158 días de media global).

PREGUNTAS (Q):

- Q12.1: ¿Cuál es el tiempo medio (en días) entre el inicio de un incidente y su detección?
- Q12.2: ¿Qué porcentaje de incidentes son detectados por controles automatizados vs. por notificación humana?
- Q12.3: ¿La cobertura SOC es 24x7 o limitada al horario laboral?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-A01a	MTTD (días)	Media de días entre inicio incidente y detección confirmada (por severidad)	Días	Mensual	> 90 días	≤ 30 días
M-A01b	Automated Detection Rate	(Incidentes detectados por controles automáticos / Total incidentes detectados) × 100	%	Mensual	< 50%	≥ 85%
M-A01c	SOC Coverage Hours	Horas de cobertura activa SOC / 168 horas semanales	%	Mensual	< 50% (horario laboral)	= 100% (24x7)

Fuentes de datos: SIEM/SOAR (tickets de incidentes), EDR/XDR, SOC reporting

Referencia normativa: NIST CSF 2.0 DE.CM; IBM Cost of Data Breach 2025 (referencia 158 días); ISO 27035

INDICADOR A-02: *Tiempo Medio de Respuesta y Contención (MTTR/MTTC)*

OBJETIVO (G):

Minimizar el tiempo entre la detección de un incidente y su contención efectiva, garantizando la capacidad de respuesta dentro de los límites establecidos por DORA Art. 17, NIS2 Art. 23 (notificación 24h/72h) y los objetivos de servicio definidos.

PREGUNTAS (Q):

- Q13.1: ¿Cuál es el tiempo medio entre la detección de un incidente crítico y su contención?
- Q13.2: ¿Existe un playbook de respuesta a incidentes documentado y probado para las tipologías más frecuentes?
- Q13.3: ¿Se cumple el requisito de notificación regulatoria de 24h (alerta temprana NIS2) y 72h (notificación completa)?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-A02a	MTTR (horas)	Media de horas entre detección y resolución de incidente (por severidad)	Horas	Por evento	> 48h críticos	≤ 4h críticos
M-A02b	MTTC (horas)	Media de horas entre detección y contención (aislamiento) del incidente	Horas	Por evento	> 24h críticos	≤ 1h críticos
M-A02c	Regulatory Notification Compliance	(Incidentes notificados en plazo / Total incidentes notificables) × 100	%	Por evento	< 100% → Sanción	= 100%
M-A02d	IR Playbook Coverage	(Tipologías de incidente con playbook probado / Total tipologías identificadas) × 100	%	Trimestral	< 50%	≥ 80%

Fuentes de datos: ITSM (ServiceNow, Jira), SOAR platform, registros de notificación INCIBE/CCN

Referencia normativa: DORA Art. 17, 19; NIS2 Art. 23; ISO 27035; ENS Op.exp.7

INDICADOR A-03: Cumplimiento de RTO/RPO (Recovery Time/Point Objective Compliance)

OBJETIVO (G):

Verificar que los Objetivos de Tiempo de Recuperación (RTO) y Punto de Recuperación (RPO) definidos para los sistemas críticos se alcanzan efectivamente en ejercicios de prueba, garantizando la resiliencia operativa conforme a ISO 22301, DORA Art. 12 y ENS Op.cont.

PREGUNTAS (Q):

- Q14.1: ¿Qué porcentaje de sistemas críticos tienen RTO y RPO formalmente definidos?

- Q14.2: ¿Se realizan pruebas periódicas de recuperación y qué porcentaje de sistemas alcanzan su RTO/RPO objetivo?
- Q14.3: ¿Cuáles son los valores de RTO y RPO para los sistemas de mayor criticidad?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-A03a	RTO/RPO Definition Coverage	(Sistemas con RTO y RPO definidos / Total sistemas críticos) × 100	%	Semestral	< 80%	= 100%
M-A03b	RTO Test Compliance Rate	(Sistemas que alcanzaron RTO en última prueba / Sistemas probados) × 100	%	Trimestral	< 80%	≥ 95%
M-A03c	RPO Test Compliance Rate	(Sistemas que alcanzaron RPO en última prueba / Sistemas probados) × 100	%	Trimestral	< 80%	≥ 95%
M-A03d	BCP Test Frequency Score	(Pruebas BCP/DRP realizadas en 12 meses / Pruebas planificadas)	Ratio	Anual	< 1,0	≥ 1,0 (mínimo 1/año)

Fuentes de datos: BCP/DRP documentation, ejercicios tabletop reports, sistema de monitorización de disponibilidad

Referencia normativa: ISO 22301:2019 §6.2, §8.5; DORA Art. 11-12; ENS Op.cont.1-4; NIST SP 800-34

INDICADOR A-04: Disponibilidad Efectiva de Servicios Críticos (Service Availability Rate)

OBJETIVO (G):

Medir el nivel real de disponibilidad de los servicios digitales críticos y verificar el cumplimiento de los SLA acordados, garantizando la continuidad del servicio conforme a los compromisos DORA Art. 8(6), SOC 2 Availability y los requisitos ENS de dimensión Disponibilidad.

PREGUNTAS (Q):

- Q15.1: ¿Cuál es el uptime efectivo de los servicios digitales críticos en el último período?
- Q15.2: ¿Existen SLA de disponibilidad definidos y monitorizados automáticamente?
- Q15.3: ¿Cuál ha sido el tiempo total de inactividad no planificada en los últimos 12 meses?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-A04a	Service Availability Rate	$(\text{Tiempo disponible} / \text{Tiempo total del período}) \times 100$	%	Mensual / Continuo	< 99%	$\geq 99,9\%$ (críticos)
M-A04b	Unplanned Downtime Hours	Suma de horas de indisponibilidad no planificada en 12 meses	Horas/año	Mensual acumulado	> 87,6h (99%)	< 8,76h (99,9%)
M-A04c	SLA Compliance Rate	$(\text{Períodos con SLA cumplido} / \text{Total períodos medidos}) \times 100$	%	Mensual	< 98%	= 100%

Fuentes de datos: Monitoring platform (Nagios, Prometheus, Datadog), ITSM (registro de incidentes de disponibilidad)

Referencia normativa: DORA Art. 8(6); SOC 2 CC Availability; ISO 27001 A.8.14; ENS Dimensión Disponibilidad

INDICADOR A-05: Índice de Resiliencia ante Ransomware (Ransomware Resilience Index)

OBJETIVO (G):

Evaluar la capacidad de la organización para resistir, detectar, contener y recuperarse de un ataque de ransomware sin pagar el rescate ni sufrir pérdida irrecuperable de datos, en el contexto de 392 ataques ransomware documentados en España en 2025 (INCIBE).

PREGUNTAS (Q):

- Q16.1: ¿Se aplica la regla 3-2-1 de copias de seguridad (3 copias, 2 medios, 1 offsite) y se verifican regularmente?
- Q16.2: ¿Las copias de seguridad están completamente aisladas de la red de producción (air-gap lógico o físico)?
- Q16.3: ¿Se han realizado ejercicios de recuperación completa ante ransomware en los últimos 12 meses?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-A05a	Backup Verification Rate	(Backups verificados (restauración exitosa) / Total backups programados) $\times$ 100	%	Mensual	< 80%	= 100%
M-A05b	Backup Isolation Score	Binario + nivel: 0=conectado siempre; 1=aislamiento lógico; 2=air-gap completo; 3=immutabilidad+air-gap	Escala 0-3	Trimestral	< 1	≥ 2
M-A05c	Ransomware Recovery Exercise Completion	(Ejercicios ransomware completados / Ejercicios planificados) $\times$ 100	%	Anual	= 0%	= 100% (al menos 1/año)
M-A05d	Time to Recover from Ransomware Simulation	Tiempo real de recuperación completa en simulacro vs. RTO definido	Ratio actual/objetivo	Anual	> 2 $\times$ RTO	$\leq 1 \times$ RTO

Fuentes de datos: Backup management platform, simulacros documentados, logs de restauración

Referencia normativa: NIST SP 800-34; ISO 22301; ENS Mp.info.9; INCIBE Ransomware Response Guide; No More Ransom

INDICADOR A-06: Tiempo Medio de Parcheo de Dispositivos de Borde (Edge Device Patch Latency)

OBJETIVO (G):

Reducir la ventana de exposición de dispositivos de borde de red (VPN, firewalls, routers, load balancers) frente a vulnerabilidades activamente explotadas, dado el incremento de 8× en su uso como vector de entrada inicial documentado en Verizon DBIR 2025.

PREGUNTAS (Q):

- Q17.1: ¿Cuántos días transcurren entre la publicación de una vulnerabilidad en dispositivos de borde y su parcheo?
- Q17.2: ¿Existe un inventario actualizado de todos los dispositivos de borde y sus versiones de firmware?
- Q17.3: ¿Se monitorizan activamente los feeds de CISA KEV para dispositivos de borde?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-A06a	Edge Device Patch Latency	Mediana de días entre publicación CVE borde y parcheo en producción	Días	Semanal	> 15 días	≤ 7 días
M-A06b	Edge Device Inventory Completeness	$(\text{Dispositivos de borde en inventario actualizado} / \text{Total dispositivos borde}) \times 100$	%	Mensual	< 90%	= 100%
M-A06c	CISA KEV Monitoring Coverage	$(\text{Dispositivos de borde con CVE KEV monitorizados} / \text{Total dispositivos borde}) \times 100$	%	Semanal	< 100% → Alerta	= 100%

Fuentes de datos: Network management platform, CISA KEV API, firmware inventory, vulnerability scanner

Referencia normativa: CISA KEV; Verizon DBIR 2025; ENS Op.exp.4; NIST SP 800-53 RA-5, SI-2

◆ EXTENSIONES CIANA: AUTENTICIDAD Y TRAZABILIDAD

INDICADOR AT-01: Índice de Trazabilidad de Sesiones Privilegiadas (Privileged Session Traceability Index)

OBJETIVO (G):

Garantizar la trazabilidad completa de todas las acciones realizadas por cuentas con acceso privilegiado a sistemas críticos, habilitando la capacidad de investigación forense y cumpliendo los requisitos de trazabilidad del ENS, DORA Art. 13(7) y NIS2 Art. 21(2)(f).

PREGUNTAS (Q):

- Q18.1: ¿Qué porcentaje de sesiones privilegiadas son grabadas y almacenadas de forma íntegra?
- Q18.2: ¿Los registros de sesiones privilegiadas son inmutables y están protegidos frente a eliminación por el propio usuario?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-AT01a	Privileged Session Recording Rate	(Sesiones privilegiadas grabadas / Total sesiones privilegiadas) × 100	%	Mensual	< 90%	= 100%
M-AT01b	Session Record Integrity Score	Binario: Registros inmutables y con control de acceso separado = 1; otro = 0	0/1	Trimestral	= 0	= 1

Fuentes de datos: PAM tool (CyberArk, BeyondTrust, Delinea), SIEM

Referencia normativa: ENS Dimensión Trazabilidad; DORA Art. 13(7); NIS2 Art. 21(2)(f); ISO 27001 A.8.15

INDICADOR AT-02: Índice de Cultura de Seguridad (Security Culture Maturity Index)

OBJETIVO (G):

Evaluar la madurez de la cultura organizacional de ciberseguridad como factor determinante del comportamiento humano frente a amenazas, dado que el 60% de las brechas globales en 2025

involucran el factor humano (Verizon DBIR 2025), y en cumplimiento de NIS2 Art. 20(2) sobre formación de órganos directivos.

PREGUNTAS (Q):

- Q19.1: ¿Qué porcentaje de empleados completa formación de ciberseguridad anualmente?
- Q19.2: ¿Cuál es la tasa de clics en simulacros de phishing?
- Q19.3: ¿Los empleados reportan activamente incidentes de seguridad?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-AT02a	Security Training Completion Rate	(Empleados con formación completada / Total empleados) × 100	%	Anual	< 70%	≥ 95%
M-AT02b	Phishing Click Rate	(Empleados que hicieron clic / Total objetivo simulacro) × 100	%	Trimestral	> 20%	< 5%
M-AT02c	Incident Reporting Rate	(Incidentes reportados por empleados / Total incidentes detectados) × 100	%	Mensual	< 20%	≥ 50%
M-AT02d	Executive Security Training Compliance	(Directivos con formación NIS2 / Total directivos) × 100	%	Anual	< 100%	= 100% (NIS2 Art. 20)

Fuentes de datos: LMS (Learning Management System), plataforma phishing simulation (KnowBe4, Proofpoint), ITSM

Referencia normativa: NIS2 Art. 20(2); ENS Org.2-3; ISO 27001 A.6.3; NIST SP 800-50

INDICADOR AT-03: Índice de Madurez Zero Trust (Zero Trust Maturity Index)

OBJETIVO (G):

Evaluar el grado de implementación de la arquitectura Zero Trust como paradigma de seguridad transversal que mejora simultáneamente los tres pilares CIA mediante el principio "nunca confiar, siempre verificar", en alineación con NIST SP 1800-35 (junio 2025) y CISA ZT Maturity Model v2.

PREGUNTAS (Q):

- Q20.1: ¿En qué fase del modelo de madurez Zero Trust se encuentra la organización?
- Q20.2: ¿Se aplican controles de microsegmentación de red?
- Q20.3: ¿La autenticación continua está implementada para usuarios con acceso a activos críticos?

MÉTRICAS (M):

ID	Nombre	Fórmula	Unidad	Frecuencia	Umbral Crítico	Objetivo
M-AT03a	ZT Maturity Level (CISA)	Nivel CISA ZT Maturity Model: 0=Tradicional; 1=Inicial; 2=Avanzado; 3=Óptimo	Escala 0-3	Semestral	= 0	≥ 2
M-AT03b	Network Microsegmentation Coverage	(Segmentos de red con microsegmentación / Total segmentos críticos) × 100	%	Trimestral	< 30%	≥ 80%
M-AT03c	Continuous Authentication Coverage	(Usuarios con autenticación continua / Total usuarios acceso crítico) × 100	%	Mensual	< 20%	≥ 70%

Fuentes de datos: CISA ZT Assessment Tool, network management, IAM platform

Referencia normativa: NIST SP 1800-35 (jun 2025); CISA ZTA Maturity Model v2; ENS (en revisión ZT)

PARTE IV: IGM-CIA — ÍNDICE GLOBAL DE MADUREZ

4.1 Fórmula de Composición

$$IGM_CIA = (w_C \times IGM_C) + (w_I \times IGM_I) + (w_A \times IGM_A)$$

Donde cada subíndice se calcula como:

$$IGM_C = (M-C01 \times 0,20) + (M-C02 \times 0,20) + (M-C03 \times 0,15) + (M-C04 \times 0,15) + (M-C05 \times 0,15) + (M-C06 \times 0,15)$$

$$IGM_I = (M-I01 \times 0,20) + (M-I02 \times 0,25) + (M-I03 \times 0,20) + (M-I04 \times 0,15) + (M-I05 \times 0,20)$$

$$IGM_A = (M-A01 \times 0,20) + (M-A02 \times 0,20) + (M-A03 \times 0,20) + (M-A04 \times 0,15) + (M-A05 \times 0,15) + (M-A06 \times 0,10)$$

Las ponderaciones w_C , w_I , w_A varían por sector (ver tabla en plantilla Excel).

4.2 Escala de Madurez IGM-CIA

IGM	Nivel CMMI Adaptado	Descripción	Acción
1,0-1,9	Inicial (Ad hoc)	Sin procesos formales; riesgo no gestionado	Plan de emergencia
2,0-2,9	Gestionado (Repetible)	Procesos básicos sin sistematización	Plan de mejora 6 meses
3,0-3,9	Definido (Documentado)	Procesos documentados y aplicados	Hoja de ruta 12 meses
4,0-4,4	Cuantitativo (Medido)	Métricas activas y decisiones basadas en datos	Optimización continua
4,5-5,0	Optimizado (Innovador)	Mejora continua con gestión predictiva	Compartir conocimiento

Marco GQM+PRAGMATIC CIA Triad v2025 · Referencias: Basili & Weiss (1984), GQM (1994), Brothby & Hinson PRAGMATIC (2013), NIST CSF 2.0, ISO/IEC 27001:2022, ENS RD 311/2022, ENISA NIS Investments 2025, IBM Cost of Data Breach 2025, Verizon DBIR 2025